

Cross-Border Data Privacy Regulations for SMEs

A practical, non-technical guide for small and medium enterprises operating in the EU, the United States (California), and China

Prepared: 26 September 2026 · Audience: non-lawyer SME owners, operations and compliance staff · Length: ~11 pages · 12 sources

Executive summary. Small and medium enterprises (SMEs) that sell online, run marketing, or employ staff across borders increasingly face a patchwork of data privacy laws. Three regulatory models matter most for global SMEs: the **European Union's GDPR** (a single comprehensive law applying wherever EU residents are targeted), the **United States' California CCPA/CPRA** (a state law with revenue- and volume-based thresholds), and **China's PIPL** (a comprehensive law with strict controls on moving personal data out of China). These regimes overlap for data about residents they protect, and they conflict in how consent, rights, and cross-border transfers are governed. The practical priority for an SME is not to become a privacy lawyer but to build one **scalable compliance backbone** — accurate privacy notices, a data inventory, a rights-response process, and a vendor-contract review step — that can satisfy the common core of all three laws at once. This brief distills each regime's obligations for SMEs, compares them side by side, identifies overlaps and conflicts, and ends with a prioritized, 90-day compliance roadmap.

1. Why this matters now

Data privacy rules are no longer a "big tech" problem. Enforcement has broadened: EU data protection authorities have issued fines not only to global platforms but also to small hospitals, local couriers, and family-run retailers. California's agency has independent enforcement power, and China's PIPL imposes penalties on organisations of every size that process personal information of people in China. At the same time, the tools an ordinary SME uses every day — website analytics, email marketing, CRM software, cloud payroll, remote-work tools — routinely transfer personal data across borders. An SME with a website that reaches EU customers, a Californian customer, or a Chinese employee can trigger one or more of these laws even if it has no office in the jurisdiction. The question is no longer *whether* a small business has privacy obligations, but *which* ones apply and how to meet them efficiently.

2. Three regimes, three models

2.1 The European Union — GDPR (Regulation (EU) 2016/679)

The GDPR is a single, directly applicable law across the EU and EEA. Its hallmark is **extraterritorial scope**: Article 3 applies the regulation to any organisation — wherever located — that offers goods or services to data subjects in the EU, or that monitors the behaviour of EU-based individuals. Large

or small, a non-EU company with an EU-facing website or EU customers falls within scope. There is **no revenue threshold** for application; size affects only selected obligations (see 2.4).

Core obligations for a controller include: a **lawful basis** for each processing purpose (consent, contract, legal obligation, legitimate interest, etc.); a concise, transparent **privacy notice**; limited data collection (data minimisation); **data-subject rights** (access, rectification, erasure/"right to be forgotten", restriction, portability, objection); **security** appropriate to risk; and, for transfers outside the EU/EEA, an "adequate" mechanism (adequacy decision, Standard Contractual Clauses, or Binding Corporate Rules). Breach notifications to the supervisory authority apply (generally within 72 hours for notifiable breaches).

Enforcement is via national supervisory authorities (e.g. the Irish DPC, French CNIL, Spanish AEPD). Fines can reach the higher of €20 million or 4% of worldwide annual turnover for the most serious infringements — but guidance and practice show that enforcement is **proportionate**, with many authorities opting for warnings, reprimands, and corrective orders for first-time or small-scale breaches.

2.2 The United States — California CCPA/CPRA

The United States has no single federal data privacy law; instead, states have enacted their own, and California is the most influential. The **CCPA** (2018), amended by the **CPRA** (effective 1 January 2023), grants California residents rights over their personal information and is enforced by the California Privacy Protection Agency (CPPA) and the Attorney General.

Unlike the GDPR, the CCPA applies only to **for-profit businesses** that do business in California and meet **at least one threshold**:

- annual gross revenue above **\$25 million** (inflation-indexed; ~\$26.6 million as of 2026); or
- buy, sell, or share the personal information of **100,000 or more** California consumers or households per year; or
- derive **50% or more** of annual revenue from selling or sharing personal information.

Businesses in scope must honour six consumer rights — **Know, Delete, Correct, Opt-out of sale/sharing, Limit** the use of sensitive personal information, and **Equal treatment** (non-discrimination) — post a privacy notice, provide "Do Not Sell or Share My Personal Information" / "Your Privacy Choices" links where applicable, honour opt-out preference signals (e.g. Global Privacy Control), and respond to requests within statutory deadlines (e.g. 45 days for know/delete/correct, extendable once). Small businesses that fall below the thresholds are largely outside the CCPA's core obligations, though they remain subject to other US laws (e.g. sectoral rules for health and finance).

Enforcement rests with the CPPA (administrative actions) and the California Attorney General (civil penalties), with statutory penalties of up to \$2,500 per negligent violation and \$7,500 per intentional violation, and a private right of action tied to data-breach scenarios.

2.3 China — PIPL

China's **Personal Information Protection Law** (PIPL, effective 1 November 2021) is a comprehensive regime modelled in part on the GDPR but with distinctive features. It applies to processing of personal information of individuals *in China*, and it has **extraterritorial reach**: overseas organisations that process personal information of people in China for purposes of

providing products/services to them, or analysing/evaluating their behaviour, must appoint a representative in China or establish an entity here for compliance, in the circumstances the law sets out.

Key obligations include: **informed consent** (or other lawful basis) with a "separate consent" requirement for handling sensitive personal information and for cross-border transfers; transparency (privacy policy); data-subject rights; and a strict **cross-border transfer regime**. To transfer personal information out of China, a processor must satisfy one of three main routes (Article 38): pass a **CAC security assessment** (for critical-information-infrastructure operators, processors handling PI of over 1 million people, or those that have already exported PI of more than 100,000 individuals or sensitive PI of more than 10,000 individuals since the prior 1 January); obtain **security certification**; or sign the **CAC standard contract** and file it with the local CAC office within 10 working days — the route most SMEs would use. In all cases the processor must notify the individual of the recipient and purpose, obtain separate consent, and conduct a **personal information protection impact assessment**.

Enforcement is by the Cyberspace Administration of China (CAC) and local offices, with the PRC's multi-agency enforcement framework and penalties for non-compliance including fines, orders to suspend activities, and (in serious cases) revocation of licences. The CAC has issued implementing measures on security assessment (effective 1 September 2022) and on the standard contract (effective 1 June 2023).

2.4 How each law treats SMEs

Aspect	GDPR (EU)	CCPA/CPRA (California)	PIPL (China)
Size-based exemption	None — applies by activity, not headcount. But SMEs fewer than 250 employees are exempt from record-keeping (Art. 30) unless processing is regular/risky; DPO only required for large-scale or sensitive processing.	Yes — below \$25M revenue and under 100k consumers/households and <50% revenue from sale/sharing, the law's core duties don't apply.	No general SME exemption; obligations apply by processing activity. Small exporters use the standard-contract route rather than security assessment.
Applies to foreign SMEs?	Yes, if offering goods/services to or monitoring individuals in the EU (Art. 3).	Only if they do business in California and meet a threshold.	Yes, for processing PI of individuals in China (extraterritorial, with representative requirement).
Primary consent model	One of several lawful bases; consent must be freely given, specific, informed, unambiguous.	Opt-out model (right to opt out of sale/sharing) plus notice; not consent-centric for most processing.	Consent-centric; "separate consent" required for sensitive PI and cross-border transfer.
Rights	Access, rectification, erasure, restriction, portability, objection.	Know, delete, correct, opt-out of sale/sharing, limit sensitive PI, equal treatment.	Access, copy, correction, deletion (with statutory conditions), withdrawal of consent.

Aspect	GDPR (EU)	CCPA/CPRA (California)	PIPL (China)
Impact assessment	DPIA required where high risk (Art. 35).	Risk assessments required for certain processing (e.g. sensitive information, automated decision-making).	PIPIA required before cross-border transfer and other high-risk processing.
Cross-border transfer tool	Adequacy decision, SCCs, BCRs, or derogations.	State law focuses on consumer rights; transfers governed by US federal rules only in specific sectors.	CAC security assessment, certification, or standard contract, plus filing and separate consent.
Maximum penalties	€20M or 4% worldwide turnover (higher).	\$2,500–\$7,500 per violation (AG/CPRA); private right of action for breaches.	Fines, orders to suspend, licence revocation in serious cases.

3. Overlap: the common core an SME can build once

Despite their differences, the three regimes share a **common core** of expectations. An SME that implements these once covers most of each law simultaneously:

- **Transparency.** All three require a clear privacy notice describing what is collected, why, with whom it is shared, and how to exercise rights. One well-written bilingual/trilingual notice template covers the base expectation.
- **Data inventory and minimisation.** You cannot comply with any law if you don't know what personal data you hold. All regimes expect you to collect no more than needed and to know where the data sits (systems, vendors, archives).
- **A rights-response process.** GDPR, CCPA/CPRA, and PIPL all give individuals the right to access, correct, and delete their data. **One shared internal workflow** — receive request, verify identity, locate data via the inventory, respond within deadline — satisfies the common core.
- **Security.** All require "appropriate" security measures proportional to risk. Encryption, access controls, staff training, and a breach-response checklist cover the baseline.
- **Third-party (processor) controls.** All three regimes expect an SME to bind its vendors by contract: GDPR via processor agreements, CCPA/CPRA via service-provider/contractor clauses restraining "selling or sharing," and PIPL via contractual safeguards for entrusted processors and recipients.
- **Impact assessment habit.** Where high-risk processing (sensitive data, profiling, cross-border transfer) occurs, all three expect a documented assessment before starting.

Key insight. Because the common core is large, an SME does not need a separate compliance program per country. It needs *one* program that is jurisdiction-aware: one data inventory, one set of notices (localised), one rights workflow, one vendor-contract review, and one set of transfer assessments. This is how a small team can stay compliant across many markets.

4. Conflicts and tension points

Where the laws diverge, an SME must handle genuine conflicts carefully:

- **Consent vs. legitimate interest.** The GDPR allows "legitimate interests" as a lawful basis without consent; China's PIPL is more consent-centric and requires separate consent for sensitive data and transfers. A single approach ("always ask for consent") can satisfy both, but it will over-collect consent under the GDPR's stricter consent standards and create friction under the CCPA's opt-out model. The pragmatic route is a legal-basis matrix per processing purpose.
- **Cross-border transfer layers.** Sending Chinese personal data to the EU requires the PIPL transfer route (standard contract, security assessment, or certification) *and*, if the data is re-exported, GDPR rules for onward transfer to third countries. Transferring EU data to a US-hosted CRM requires SCCs or an adequacy decision; California has no separate "export" rule for data going out of state. A single global cloud vendor may trigger two or three transfer regimes at once.
- **Data retention and the "right to be forgotten."** GDPR and CCPA/CPRA allow deletion with specific exceptions (e.g. legal or accounting retention). China's PIPL also provides for deletion when processing purposes are achieved, but Chinese record-keeping laws (e.g. accounting and e-commerce retention rules) can interact with that. An SME must reconcile "delete on request" with "keep for tax records" by defining which datasets are subject to which exception.
- **Enforcement forum.** A data breach involving EU, Californian, and Chinese individuals can attract three regulators. Priorities vary: EU authorities emphasise individual rights; the CPPA/AG emphasise consumer protection and transparency; the CAC emphasises national security and data localisation. An incident-response plan should anticipate multiple notifications.

5. Frequent SME misconceptions

- **"We're too small to be regulated."** Under the GDPR and PIPL there is no size exemption; both turn on activity, not headcount. Under the CCPA, size-based thresholds *do* exclude many small businesses — but only if they actually stay below the thresholds.
- **"We don't have an office there, so the law doesn't apply."** Extraterritorial reach (GDPR Art. 3, PIPL) and "doing business in California" (CCPA) can apply to a foreign SME based entirely on customers, employees, or website audience.
- **"Consent solves everything."** Consent is necessary for some processing but not sufficient for all; and the CCPA is primarily an opt-out regime where asking for consent is not the operative mechanism at all.
- **"Using a big US cloud provider makes us compliant."** A large vendor's own compliance does not transfer to you: the GDPR requires the *controller* (you) to ensure a valid transfer mechanism; the PIPL requires the *processor* (you or your vendor) to satisfy the export route; the CCPA requires *your* notices and rights responses.

6. Worked example — "Atlas Craft Studio" (a typical SME)

To make the framework concrete, consider a fictional but representative SME: *Atlas Craft Studio*, a 40-person maker of home goods. Atlas sells worldwide through its own website and an e-commerce marketplace, uses a US-based cloud CRM for customer marketing, runs payroll and HR through a global software platform, and last year hired two remote engineers in China plus one contractor in Spain. It has no offices outside its home country.

Which laws are triggered?

- **GDPR:** Atlas's website ships to EU customers and its newsletter targets EU subscribers, so the GDPR applies to the personal data of those individuals (Article 3). The 40-person size exempts Atlas from maintaining its Article 30 records *unless* the processing is regular or risky — marketing a customer list is regular processing, so Atlas should keep at least a lightweight record.
- **CCPA/CPRA:** Atlas sells to Californian customers and its CRM holds their data. Whether the CCPA applies depends on thresholds. If Atlas's annual gross revenue stays under the (~\$26.6M) revenue figure, it buys/sells/shares data of fewer than 100,000 Californians, and derives less than 50% of revenue from selling/sharing personal information, the CCPA's core duties do not apply. Atlas's marketing is not "selling" (no transfer of data to third parties for money), so for many SMEs the CCPA is simply not triggered. *This is the key difference from the GDPR: an SME can be entirely outside California's law.*
- **PIPL:** Atlas processes personal information of its two remote engineers in China (their names, contact details, payroll data, employment records). The PIPL applies to that processing, and overseas transfer of those records to Atlas's home-country payroll system triggers the cross-border transfer regime. The standard-contract route (not a full CAC security assessment) is the proportionate path for a two-person dataset: sign the CAC standard contract, obtain the employees' separate consent, conduct the impact assessment, and file with the local CAC office.

What Atlas actually needs to do:

1. Document that its EU marketing rests on a lawful basis (legitimate interest or consent) and its notices reflect that.
2. Confirm it is below the CCPA thresholds in a short memo, and keep the evidence (revenue and data-volume figures) so it can re-check annually — thresholds change and "sharing" for advertising could raise questions.
3. Handle the Chinese engineers' data as a deliberate project: standard contract, separate consent, impact assessment, filing, and a representative/contact point in China as the law requires for overseas processors.
4. Add data-protection clauses to its CRM and HR-platform contracts so those vendors are contractually bound (processor terms under the GDPR, service-provider terms under the CCPA where relevant).
5. Build the rights-response workflow once and reuse it for EU and Chinese individuals (and Californians if a threshold is ever crossed).

The Atlas example shows the practical ordering: one privacy backbone (inventory, notices, rights workflow, vendor terms, security) handles the common core for all three regimes; the jurisdiction-specific steps — the Chinese transfer package, the CCPA threshold memo — are small, discrete additions on top of it.

7. How to build this on a small budget

- **Use existing tools.** A spreadsheet is a perfectly adequate data inventory for a 40-person company. Don't buy privacy software before you have the inventory; the discipline matters more than the tool.

- **One lawyer, one review.** The most efficient legal spend is a single paid review of your notices, vendor clauses, and the Chinese transfer package — not an ongoing retainer. Free/cheap resources (EU SME guidance, EDPB guidelines, CPPA FAQs, DigiChina translations) cover the reading material.
- **Template once, localise everywhere.** Write the privacy notice once; localise for the three markets. The core content is ~80% identical.
- **Automate the request channel.** A shared mailbox and a simple form are enough; none of the three laws requires a fancy portal.
- **Treat privacy as a recurring calendar item.** A half-day quarterly review (new tools? new country? new data type?) keeps the program alive without a dedicated hire.

8. Frequently asked questions

- **Q: We only have 5 employees — do we really have to comply with the GDPR?** A: The GDPR has no employee-count exemption for the basic obligations. If you process EU residents' data (even a few customers), the core duties of lawful basis, notice, rights, and security apply. The 250-employee threshold only lightens *record-keeping*, and only when processing is not regular or risky.
- **Q: What is the minimum we must do for the CCPA?** A: First determine whether you meet a threshold. Most micro-businesses don't. If you do, the minimum is a privacy notice, a rights-response process for know/delete/correct, the "Do Not Sell or Share" link where you sell or share, and honouring opt-out signals.
- **Q: Can we just block all traffic from the EU and China to avoid these laws?** A: Technically often possible for the website, but it is not a clean solution: it excludes legitimate customers, and employment data (as in the Atlas example) does not depend on website traffic at all. A block is a business decision, not a compliance strategy.
- **Q: Which law is strictest for a small company?** A: In practice the GDPR is the most onerous for a foreign SME because there is no size threshold. China's PIPL is demanding specifically around cross-border transfers (separate consent, standard contract, impact assessment). The CCPA is the most forgiving for small companies because its thresholds exclude them.
- **Q: Do we need a Data Protection Officer?** A: Only if you are a public authority, or (under the GDPR) if your core activities require large-scale regular and systematic monitoring or large-scale processing of sensitive data. A 40-person maker of home goods almost certainly does not.
- **Q: Are cookies and analytics in scope?** A: Yes, where they collect personal data. EU rules on ePrivacy/cookies sit alongside the GDPR; California's "sharing" concept covers cross-context behavioural advertising (which web analytics can trigger if the data is shared with ad platforms); China regulates the use of tracking and personal information in e-commerce. Use consent banners and assess whether your analytics data is personal data.

9. Gap analysis — what an SME typically lacks

Capability	Typical starting state	Gap vs. common core	Fix
Data inventory	None or partial; data scattered in CRM, spreadsheets, email, cloud files, payroll	Cannot answer access/delete requests; cannot assess transfers	Build a simple register: system, data categories, purpose, retention, vendor
Privacy notice	Generic placeholder or absent	Transparency duty unmet in all regimes	One template, localised per market; reviewed by counsel once
Rights-response workflow	None; requests land in a general inbox	Statutory deadlines missed	Shared mailbox + form; 45-day (CCPA) / 1-month (GDPR) target
Vendor contracts	Standard terms, no data-protection clauses	Processor/recipient obligations unbound	Review top 5 data vendors; add DPA / service-provider clauses
Cross-border analysis	None; "the cloud" assumed safe	GDPR SCCs, PIPL transfer route unaddressed	Map where data flows; pick a transfer tool per route
Security baseline	Ad hoc password practices	All regimes require proportionate security	MFA, access control, staff training, breach checklist

10. Prioritised compliance roadmap (90 days)

This roadmap assumes a small team with limited budget. It front-loads the common core (which de-risks all three regimes at once) and defers jurisdiction-specific extras until the underlying backbone exists.

Days 1–30: Foundation (the common core)

1. **Assign an owner.** A named person (even part-time) responsible for privacy — the "go-to" for regulators and customers.
2. **Build the data inventory.** List every tool that handles personal data (website, CRM, email, payroll, analytics, support), the categories of data (names, emails, addresses, device data, health data if any), the purpose for each, retention, and the vendors involved. This is the single highest-leverage step.
3. **Write one privacy notice** that says what is collected, why, who it is shared with, how long it is kept, what rights exist, and how to contact you. Localise it for each market (EN for EU, EN/ES for California, ZH for China).
4. **Stand up a rights-response channel** (email address + web form) and a 1-month/45-day internal SLA.

Days 31–60: Contracts, security, and transfers

5. **Review the top 5 data-processing vendors.** Add data-protection clauses to your contracts (a data-processing agreement for EU; service-provider/contractor language for California; processor safeguards for China). Refuse vendors unwilling to sign.

6. **Map cross-border flows and pick transfer tools.** For EU data going outside the EEA: ensure SCCs (or use an EU/UK-approved processor with them). For Chinese personal data leaving China: prepare the CAC standard contract and impact assessment, file with the local CAC within 10 working days of signing, and obtain separate consent. For California: there is no separate export rule, but note the "sharing" disclosure duty if data is shared for cross-context behavioural advertising.
7. **Implement the security baseline:** multi-factor authentication on admin accounts, least-privilege access, full-disk encryption on laptops, a staff one-hour privacy/security training, and a documented breach-response checklist (including the 72-hour EU notification trigger and multi-regulator notification plan).

Days 61–90: Operationalise and evidence

8. **Add consent and preference management** where required: separate consent flows for sensitive data and transfers (China), clear opt-out for sale/sharing (California, if applicable), and lawful-basis documentation (EU).
9. **Run one "dry-run rights request"** end-to-end to prove the workflow works, and fix what fails.
10. **Document everything** — the inventory, the notices, the vendor register, the assessments. Evidence that you have a program is itself a compliance asset with every regulator, and it is the first thing a regulator's questionnaire asks for.
11. **Maintain cadence:** an annual review plus re-checks whenever a new tool, new country, or new data type is added.

11. What to do if enforcement or a complaint arrives

1. **Don't ignore it.** All three regimes reward demonstrable good faith and corrective action; ignoring a letter escalates it.
2. **Confirm the trigger.** Identify the processing, the data at issue, the applicable law, and whether the request/complaint is from an individual, a regulator, or a court.
3. **Preserve evidence** of your inventory, notices, contracts, and assessments — it shows your program existed and was proportionate.
4. **Respond within deadlines** (individual requests: 1 month under GDPR, 45 days under CCPA; regulator inquiries promptly).
5. **Engage counsel** for anything involving penalties or cross-border transfers. This brief is a compliance primer, not legal advice.

12. Conclusion

The right frame is not "comply with three GDPR-like laws." It is: **build one privacy backbone that is jurisdiction-aware.** A data inventory, a privacy notice, a rights-response workflow, vendor controls, security basics, and transfer assessments — done once and maintained — put an SME in a defensible position under the GDPR, the CCPA/CPRA, and the PIPL at the same time. The regimes differ sharply in thresholds, consent mechanics, and transfer tools; they converge on transparency, accountability, and individual rights. For a small team with a global footprint, that convergence is the practical opportunity: invest in the backbone first, layer the jurisdiction-specific details second, and

keep the evidence. Proportionality — matching effort to the real risk your processing creates — is not just acceptable; it is what each of these laws, in its own way, actually requires.

Sources

1. Regulation (EU) 2016/679 (General Data Protection Regulation). EUR-Lex. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
2. European Commission — "Application of the GDPR." https://commission.europa.eu/law/law-topic/data-protection/information-business-and-organisations/application-gdpr_en
3. GDPR.eu — "Does the GDPR apply to companies outside of the EU?" <https://gdpr.eu/companies-outside-of-europe/>
4. GDPR-info.eu — consolidated GDPR text. <https://gdpr-info.eu/>
5. European Data Protection Board — Guidelines and Recommendations. https://edpb.europa.eu/our-work-tools/general-guidance/gdpr-guidelines-recommendations-best-practices_en
6. California Consumer Privacy Act (Civil Code §1798.100 et seq.), as amended by the CPRA. https://leginfo.ca.gov/faces/codes_displaySection.xhtml?lawCode=CIV§ionNum=1798.100.
7. California Privacy Protection Agency — FAQs. <https://cppa.ca.gov/faq.html>
8. California Attorney General — CCPA page. <https://oag.ca.gov/privacy/ccpa>
9. Personal Information Protection Law of the People's Republic of China (effective 1 Nov 2021) — English translation, DigiChina Project, Stanford University. <https://digichina.stanford.edu/work/translation-personal-information-protection-law-of-the-peoples-republic-of-china-effective-nov-1-2021/>
10. Cyberspace Administration of China — "Measures on Standard Contracts for the Export of Personal Information" and Standard Contract (24 Feb 2023; effective 1 Jun 2023). http://www.cac.gov.cn/2023-02/24/c_1678884830036813.htm
11. Qian Sun, "Cross-Border Data Transfer Mechanism in China and Its Compliance," California Lawyers Association (Mar 2023). <https://calawyers.org/business-law/cross-border-data-transfer-mechanism-in-china-and-its-compliance/>
12. Thomson Reuters Practical Law — "Understanding the California Consumer Privacy Act (CCPA)."
<https://legal.thomsonreuters.com/blog/the-california-consumer-privacy-act/>

Prepared as a general information resource for SME owners and operations staff. It summarises publicly available regulatory information and is not legal advice. For decisions involving penalties, litigation, or cross-border data transfers, consult a qualified professional in the relevant jurisdiction.